NES AI FINANCE & INSURANCE INTELLIGENCE PLATFORM

Security, Privacy & Threat Model

Document ID: NES-SEC-010 | **Version:** 1.0

Build approach: Cline-assisted development • Local-first Windows application

Scope: Personal research, paper trading and insurance document assistance

Local-first security, data handling and recovery

1. Security objectives

- Keep the app bound to localhost by default unless the user explicitly configures network access.
- Protect API credentials, personal policy documents and exported reports.
- Minimise sensitive data collection and redact logs.
- Make backup, restore and deletion behaviour explicit.

2. Threat areas

Threat	Mitigation
Local network exposure	Bind services to loopback by default; document any LAN exposure and authentication implications.
Credential leakage	Keep secrets out of client bundles, source control, screenshots and logs; use local environment/config mechanisms.
Malicious uploads	Validate file types/size; parse defensively; avoid executing uploaded content.
Sensitive logs	Log event IDs/statuses, not full policy text, credentials or unnecessary identifiers.
External data transfer	Disclose any service that sends document/query data outside the PC; require explicit approval.
Backup theft/corruption	Document storage location, encryption options, restore tests and backup retention.

Threat	Mitigation
Incorrect deletion	Provide confirmation and document whether backups also retain the deleted item.
AI prompt injection in documents	Treat document content as untrusted data; never allow document text to override system controls.

3. Local-first privacy rules

- Use synthetic data during the frontend prototype.
- Store real documents only after access controls, path handling and deletion are tested.
- Avoid automatic cloud sync for policy PDFs unless explicitly configured.
- Separate user-facing reports from diagnostic logs.
- Keep a record of which AI model/provider processed each request when applicable.

4. Backup and recovery

- Define what is backed up: database, document files, configuration and reports.
- Do not include secrets in plain-text backups by default.
- Test restoring to a clean local directory or machine profile.
- Define recovery steps for database corruption and missing documents.
- Explain retention and deletion behaviour in the user guide.

5. Operational checklist

- Dependency audit and lockfile review.
- Secret scanning and safe error handling.
- File upload size/type limits.
- Localhost/network binding check.
- Backup/restore test.
- Data deletion test.
- External data-flow review before enabling any third-party integration.

6. Scope boundary

This document is a practical baseline, not a formal security certification. Reassess threats before enabling remote access, customer accounts, live trading, insurance distribution or any external service that receives sensitive data.